CRISC Domain A - 100 More Impossible Hard Questions

Governance - Expert Level Part 2

CRISC Mastery Series

October 21, 2026

Warning

Extreme Difficulty

These questions test the deepest governance judgment.
Every option will look plausible.
You must think like a board advisor, not a technician.

Outline

1. 1. Strategic Alignment and Governance
2. 2. Legal, Regulatory and Ethical Requirements
3. 3. Roles and Responsibilities
4. 4. Enterprise Risk Management
5. 5. Risk Culture
6. 6. Third-Party Governance
7. 7. Risk Appetite, Tolerance and Reporting
8. 8. Business Continuity Governance
9. 9. IT Resource and Performance Governance
10. 10. Advanced Governance Scenarios

Q101: Strategy Cascade

Question

The CEO announces a digital transformation strategy. The risk practitioner must translate this into IT risk priorities. What is the BEST FIRST step?

A. Purchase new tools

B. Identify business objectives, drivers, and dependencies introduced by the strategy

C. Hire more analysts

D. Approve more projects

Q101: Explanation

Correct Answer: B

Strategy defines the risk agenda:

- Strategy reveals new dependencies and objectives
- Objectives anchor risk priorities
- Tools and headcount follow the priorities

Critical Trap

Strategy defines the risk agenda, not the reverse.

Q102: Board Knowledge of IT

Question

The board admits it does not understand a major IT risk presented to it. What governance action is BEST?

A. Approve and move on

B. Request a focused briefing and independent verification before decision

C. Postpone indefinitely

D. Delegate to the IT vendor

Q102: Explanation

Correct Answer: B

Understanding precedes decision:

- Understanding precedes decision
- Independent verification reduces blind spots
- Postponement delays important action

Critical Trap

Boards must understand before deciding.

Q103: Ethical Judgment Escalation

Question

An executive directs a team to hide a security incident from the board. What should the practitioner do?

A. Comply silently
B. Escalate through ethics, audit, or legal channels
C. Ignore
D. Delay reporting

Q103: Explanation

Correct Answer: B

Concealment violates governance:

- Concealment violates governance
- Channels exist for escalation
- Silence compounds exposure

Critical Trap

Concealment violates the Code of Ethics.

Q104: Governance of Decisions

Question

An IT decision changes the enterprise risk profile materially. What governance principle MOST applies?

A. IT can decide independently

B. Material changes require escalation and approval per governance thresholds

C. Vendors decide

D. The change can proceed

Q104: Explanation

Correct Answer: B

Material change needs governance approval:

- Material changes need authority
- Thresholds define escalation
- Silent change loses oversight

Critical Trap

Material change needs governance approval.

Q105: Policy Cascade

Question

The board approves a new high-level policy. What is the NEXT governance step?

A. Archive the policy
B. Cascade into standards and procedures with owners and timelines
C. Notify regulators
D. Approve budget

Q105: Explanation

Correct Answer: B

Policy without cascade is a document:

- Policy requires implementation
- Standards and procedures operationalize intent
- Owners and timelines drive action

Critical Trap

Policy without cascade is a document, not a control.

Q106: Risk Appetite Revisited

Question

The business strategy shifts from stability to aggressive growth. What should happen to risk appetite?

A. Remain unchanged
B. Be reconsidered and re-approved to reflect the new strategy
C. Decrease
D. Increase without review

Q106: Explanation

Correct Answer: B

Appetite follows strategy:

- Appetite follows strategy
- Board re-approves appetite
- Changes must be deliberate

Critical Trap

Appetite follows strategy, with board approval.

Q107: Management Versus Board

Question

Who decides whether to accept a risk that exceeds the stated appetite?

A. The risk practitioner

B. The board of directors or its delegated authority per policy

C. The IT manager

D. The vendor

Q107: Explanation

Correct Answer: B

Above-appetite acceptance is board-owned:

- Accepting above appetite is a board-level decision
- Delegation must be defined
- Practitioners advise, not decide

Critical Trap

Above-appetite acceptance is board-owned.

Q108: Board Committee Structure

Question

A board creates a technology risk committee. What is the PRIMARY benefit?

A. More meetings
B. Focused expertise and oversight on technology risk
C. Cheaper operations
D. Avoidance of audits

Q108: Explanation

Correct Answer: B

Committees deepen expertise:

- Committees deepen expertise
- Focus improves decisions
- Costs and audits are not the goal

Critical Trap

Committees deepen expertise and focus.

Q109: Risk Committee Authority

Question

A risk committee debates risks but has no authority to require action. What is the MAIN gap?

A. Too many members
B. Missing authority and escalation paths to enforce actions
C. Too much data
D. Too few vendors

Q109: Explanation

Correct Answer: B

Debate without authority stalls action:

- Committees need authority or escalation
- Debate without power delays action
- Defined authority supports effectiveness

Critical Trap

Debate without authority stalls action.

Q110: Role Clarity

Question

The CISO and the CRO both claim ownership of IT risk reporting. What is the BEST resolution?

A. The CISO reports

B. Define responsibilities through a RACI or governance policy; the CRO typically owns enterprise risk reporting

C. The CIO reports

D. Vendor reports

Q110: Explanation

Correct Answer: B

Overlaps are resolved with clarity:

- Overlap creates conflict
- RACI clarifies roles
- Enterprise risk reporting usually sits with the CRO

Critical Trap

Overlaps are resolved with clarity, not hierarchy.

Q111: M and A Governance

Question

An acquisition introduces unknown IT risk. What governance decision is MOST urgent?

A. Approve branding changes

B. Assign ownership and authorize an assessment before integration

C. Increase marketing budget

D. Cancel the acquisition

Q111: Explanation

Correct Answer: B

Acquisitions need owners and assessment:

- Ownership enables action
- Assessment prevents surprises
- Cancellation needs evidence

Critical Trap

Acquisitions need owners and assessment first.

Q112: Board Oversight of Outages

Question

Repeated outages are reported to the board without corrective action. What is the BEST board response?

A. Approve the status quo

B. Require a remediation plan with owners and timelines

C. Ignore the outages

D. Reduce monitoring

Q112: Explanation

Correct Answer: B

Repeated failures demand remediation:

- Boards require action
- Owners and timelines create accountability
- Ignoring normalizes failure

Critical Trap

Repeated failures demand remediation plans.

Q113: Executive Removal of Controls

Question

An executive orders removal of a control to speed a project. What governance principle MOST applies?

A. Executive authority overrides all controls
B. Changes to controls require risk assessment and approval per policy
C. The project should proceed
D. Vendors should decide

Q113: Explanation

Correct Answer: B

Removing controls needs assessment:

- Controls exist for reasons
- Removal requires assessment and authority
- Speed is not a reason to bypass governance

Critical Trap

Removing controls needs assessment and authority.

Q114: Decision Rights Matrix

Question

The organization lacks defined decision rights for IT risk. What is the MOST likely consequence?

A. Faster decisions

B. Confusion, delays, and unassigned accountability

C. Lower cost

D. Better audits

Q114: Explanation

Correct Answer: B

Undefined rights create drift:

- Without rights, decisions drift or stall
- Roles become ambiguous
- Governance requires clarity

Critical Trap

Undefined rights create drift and confusion.

Q115: Board Accountability

Question

A major failure occurs after the board ignored warnings from management. Who is accountable?

A. Management only

B. The board and management, per their defined roles

C. The auditor

D. The vendor

Q115: Explanation

Correct Answer: B

Accountability follows oversight roles:

- Boards oversee
- Management operates
- Both hold defined accountabilities

Critical Trap

Accountability follows defined oversight roles.

Q116: Data Breach Notification

Question

A breach affects customers in multiple countries with different notification rules. What should governance require?

- A Notify only one country
- B Use a consistent notification process that satisfies all applicable requirements
- C Delay until resolution
- D Avoid notifications

Q116: Explanation

Correct Answer: B

Notification must satisfy every jurisdiction:

- Consistency supports compliance
- Multiple rules require careful design
- Delay violates laws

Critical Trap

Breach notification must satisfy every jurisdiction.

Q117: Data Sovereignty

Question

A regulation requires data to remain in-country. The vendor stores data abroad. What governance action is BEST?

A. Accept the vendor's statement

B. Reassess the vendor relationship and design controls to meet sovereignty requirements

C. Ignore the regulation

D. Expand the vendor's role

Q117: Explanation

Correct Answer: B

Sovereignty overrides convenience:

- Sovereignty is a hard constraint
- Controls must meet the requirement
- Ignoring the law is not an option

Critical Trap

Sovereignty overrides vendor convenience.

Q118: Ethical Sourcing

Question

A supplier violates human rights standards. What governance response is BEST?

A. Ignore it

B. Assess exposure, require remediation, or exit the relationship per policy

C. Increase orders

D. Hide it

Q118: Explanation

Correct Answer: B

Ethical sourcing is a governance obligation:

- Ethics are part of governance
- Options include remediation or exit
- Ignoring damages reputation and values

Critical Trap

Ethical sourcing is a governance obligation.

Q119: Conflicts with Law

Question

An internal policy conflicts with local law. What is the BEST governance action?

- A Follow policy
- B Follow the law and escalate to update the policy
- C Ignore both
- D Delegate to the vendor

Q119: Explanation

Correct Answer: B

Law outranks internal policy:

- Law takes precedence over internal policy
- Policy must be updated
- Silence endangers the enterprise

Critical Trap

Law outranks internal policy.

Q120: Professional Ethics

Question

The practitioner is asked to sign a report they believe is materially misleading. What should they do?

A. Sign it

B. Refuse, document concerns, and escalate per the Code of Ethics

C. Modify the report silently

D. Resign without action

Q120: Explanation

Correct Answer: B

The Code of Ethics requires honesty:

- Honesty is a professional duty
- Documentation preserves evidence
- Escalation is the proper path

Critical Trap

The Code of Ethics requires honesty.

Q121: Confidentiality Obligations

Question

A client's confidential data is requested by a third party. What governs disclosure?

- A Curiosity
- B Legal obligation or authorized request under contract and law
- C Convenience
- D No rules apply

Q121: Explanation

Correct Answer: B

Disclosure requires legal authority:

- Disclosure needs legal authority
- Contracts define permitted sharing
- Casual disclosure breaches confidentiality

Critical Trap

Disclosure requires legal authority.

Q122: Cross-Border Transfer

Question

Data must be transferred between jurisdictions. What governance step is MOST important?

A. Transfer without checks
B. Confirm lawful transfer mechanisms and controls are in place
C. Delay indefinitely
D. Use the cheapest method

Q122: Explanation

Correct Answer: B

Lawful mechanisms precede transfers:

- Lawful mechanisms are required
- Controls ensure protection
- Cost is not the primary factor

Critical Trap

Lawful mechanisms precede transfers.

Q123: Regulatory Inspection

Question

A regulator requests documents during an inspection. What governance response is BEST?

- A Delay and minimize
- B Respond fully and honestly per legal guidance
- C Refuse
- D Provide false documents

Q123: Explanation

Correct Answer: B

Honest cooperation protects the enterprise:

- Honest cooperation is required
- Legal guidance ensures accuracy
- Refusal and falsehood worsen exposure

Critical Trap

Honest cooperation protects the enterprise.

Q124: Contracting Ethics

Question

A contract clause requires the organization to breach its own ethics code. What should governance do?

A. Comply silently

B. Refuse, escalate, and renegotiate the clause

C. Ignore the code

D. Terminate immediately without discussion

Q124: Explanation

Correct Answer: B

Ethics are non-negotiable:

- Ethics clauses matter
- Renegotiation is the first step
- Silent breach damages integrity

Critical Trap

Ethics are non-negotiable; contracts can be.

Q125: Records Retention

Question

A retention schedule conflicts with a legal hold. What should governance require?

A. Destroy records per schedule

B. Preserve records under legal hold until released

C. Ignore the hold

D. Delete everything

Q125: Explanation

Correct Answer: B

Legal holds override retention rules:

- Legal holds override retention schedules
- Destruction during a hold is a serious violation
- Preservation protects the enterprise

Critical Trap

Legal holds override retention rules.

Q126: Risk Owner Authority

Question

A risk owner lacks the authority to approve the required budget. What should happen?

A. Approve without authority

B. Reassign ownership to someone with authority or escalate for authorization

C. Ignore the risk

D. Lower the rating

Q126: Explanation

Correct Answer: B

Ownership needs authority to act:

- Ownership requires authority
- Reassignment or escalation resolves the gap
- Lowering ratings hides the issue

Critical Trap

Ownership needs authority to act.

Q127: Data Ownership Handover

Question

The data owner leaves the company. What is the MOST important governance action?

A. Delete the data

B. Formally assign a new data owner with documented classification and access rights

C. Ignore the departure

D. Delegate to the vendor

Q127: Explanation

Correct Answer: B

Data ownership must be handed over formally:

- Formal handover preserves accountability
- Access rights must be updated
- Orphaned data risks exposure

Critical Trap

Data ownership must be handed over formally.

Q128: Three Lines in Crisis

Question

During an incident, the first line is overwhelmed. Can the second line take over operational response?

A. Yes, without conditions

B. Yes, if done through defined crisis procedures with clear authority

C. No, never

D. Only the third line may respond

Q128: Explanation

Correct Answer: B

Crisis roles can shift with governance:

- Crisis roles can shift if defined
- Clear authority prevents confusion
- Independence is preserved via process

Critical Trap

Crisis roles can shift, but with governance.

Q129: Audit Committee Independence

Question

The audit committee chair also runs operations. What is the concern?

A. Stronger oversight

B. Compromised independence and potential conflict of interest

C. Lower cost

D. Better reporting

Q129: Explanation

Correct Answer: B

Independence cannot be compromised:

- Independence is essential to oversight
- Combining operations and audit roles weakens challenge
- Governance requires separation

Critical Trap

Independence cannot be compromised.

Q130: Board Technology Advisor

Question

The board hires an external technology advisor. What governance benefit is MOST likely?

A. Cheaper decisions

B. Independent expertise to improve oversight quality

C. Faster meetings

D. Vendor preference

Q130: Explanation

Correct Answer: B

Advisory expertise strengthens oversight:

- Expertise deepens oversight
- Independence supports objectivity
- Cheaper is not the goal

Critical Trap

Advisory expertise strengthens oversight.

Q131: Executive Reporting Line

Question

The CISO reports to the CIO, and the CIO is under investigation for control failures. What governance issue is MOST likely?

A. Independence of the CISO may be compromised
B. Faster reporting
C. Lower cost
D. Better culture

Q131: Explanation

Correct Answer: A

Reporting lines affect independence:

- Independence protects security oversight
- Conflict may deter honest reporting
- Governance must review reporting lines

Critical Trap

Reporting lines affect independence.

Q132: Committee Quorum

Question

A critical risk committee often fails to meet quorum. What governance action is BEST?

A. Ignore the failures

B. Review membership, delegation, and meeting cadence to ensure quorum

C. Cancel the committee

D. Add more members without structure

Q132: Explanation

Correct Answer: B

Committees must function:

- Quorum ensures decisions
- Membership and delegation support attendance
- Adding members without structure may worsen

Critical Trap

Committees must function.

Q133: Delegated Authority

Question

A manager approves expenditures above their delegated authority. What is the governance finding?

A. Acceptable

B. A breach of delegated authority requiring review and corrective action

C. Faster decisions

D. Good practice

Q133: Explanation

Correct Answer: B

Authority limits exist for a reason:

- Limits define authority
- Breaches require investigation
- Tolerance for overreach erodes governance

Critical Trap

Authority limits exist for a reason.

Q134: Shadow Ownership

Question

Multiple teams claim to own the same data. What is the MAIN governance risk?

A. Accountability confusion
B. Faster processing
C. Lower cost
D. Better controls

Q134: Explanation

Correct Answer: A

Single owner prevents gaps:

- Ownership must be single and clear
- Confusion leads to gaps
- Controls degrade without ownership

Critical Trap

Single owner prevents gaps.

Q135: Governance of Shared Services

Question

A shared service is used by many business units. Who is accountable for its risk?

A. The business unit with the largest budget

B. A designated owner with cross-functional authority and clear accountability

C. The vendor

D. Nobody

Q135: Explanation

Correct Answer: B

Shared services need single ownership:

- Shared services need a single owner
- Cross-functional authority enables decisions
- Unclear ownership creates unmanaged risk

Critical Trap

Shared services need single ownership.

Q136: Risk Universe Refresh

Question

The business enters a new market. What is the FIRST thing to update in the risk universe?

A. Vendor list

B. Business objectives and dependencies introduced by the market entry

C. Marketing plan

D. Holiday schedule

Q136: Explanation

Correct Answer: B

New markets reshape the risk universe:

- Strategy changes the risk universe
- New dependencies emerge
- Objectives define priorities

Critical Trap

New markets reshape the risk universe.

Q137: Risk Aggregation

Question

Aggregation across business units may hide a concentration. What is the BEST governance response?

A. Ignore the concentration
B. Present both aggregate and drill-down views to reveal concentration
C. Reduce reporting
D. Increase budgets

Q137: Explanation

Correct Answer: B

Aggregation must allow drill-down:

- Aggregate views hide concentration
- Drill-down reveals exposure
- Governance needs visibility

Critical Trap

Aggregation must allow drill-down.

Q138: Emerging Risk Register

Question

Which source BEST feeds the emerging risk register?

A. Historical incidents only
B. Threat intelligence, regulatory horizon scanning, and strategic changes
C. Vendor brochures
D. Employee surveys only

Q138: Explanation

Correct Answer: B

Emerging risks need forward-looking sources:

- Emerging risks have little history
- Horizon scanning and intelligence reveal trends
- Brochures and surveys add context but not emerging risk signals

Critical Trap

Emerging risks need forward-looking sources.

Q139: Risk Tolerance Translation

Question

The board tolerance is expressed in financial loss. How should this translate into operational metrics?

A. No translation needed

B. Define operational indicators that correlate with financial tolerance

C. Ignore the financial tolerance

D. Use industry averages only

Q139: Explanation

Correct Answer: B

Tolerance must become measurable:

- Operational metrics must connect to financial limits
- Correlation supports early warning
- Ignoring tolerance breaks governance

Critical Trap

Tolerance must become measurable operations.

Q140: Risk Committee Decisions

Question

A risk committee decision conflicts with a business unit's plan. What is the BEST path?

A. The business unit proceeds
B. Escalate to the appropriate authority for resolution
C. Ignore the committee
D. Cancel the project

Q140: Explanation

Correct Answer: B

Conflicts go to authority:

- Conflict requires escalation
- Authority resolves conflicts
- Silent proceeding breaks governance

Critical Trap

Conflicts go to authority, not silent override.

Q141: Risk Profile Update

Question

Risk profile updates should be triggered by:

A. Only annual cycles
B. Material changes, incidents, and periodic cadence
C. Only audits
D. Only board meetings

Q141: Explanation

Correct Answer: B

Update profiles on change:

- Material changes alter the profile
- Incidents reveal gaps
- Periodic cadence prevents drift

Critical Trap

Update profiles on change, not just on schedule.

Q142: Risk Appetite Cascade

Question

A board appetite statement exists but business units operate to different thresholds. What governance gap is MOST likely?

A. No gap
B. Missing translation and communication of appetite to the operational level
C. Too many thresholds
D. Too few metrics

Q142: Explanation

Correct Answer: B

Untranslated appetite drifts:

- Appetite must be operationalized
- Without translation, units drift
- Communication aligns behavior

Critical Trap

Untranslated appetite drifts at the operational level.

Q143: Risk Reporting to Regulators

Question

A regulator asks for evidence of risk oversight. What content is MOST valuable?

- A Marketing summary
- B Evidence of governance structures, decisions, escalations, and remediations
- C Vendor brochures
- D Employee birthdays

Q143: Explanation

Correct Answer: B

Oversight requires evidence:

- Regulators need evidence of governance
- Decisions and escalations show oversight
- Remediations show action

Critical Trap

Oversight requires evidence, not slogans.

Q144: Risk Communication Quality

Question

Which risk communication is MOST likely to trigger appropriate action?

A. Vague fear
B. Clear risk, business consequence, options, and recommendation
C. Technical jargon
D. Too many details

Q144: Explanation

Correct Answer: B

Clarity moves leaders to act:

- Clear options drive action
- Business consequence aligns with decisions
- Jargon and volume obscure

Critical Trap

Clarity moves leaders to act.

Q145: Key Risk Indicators

Question

A KRI has been green for years but a breach occurred. What is the MOST likely cause?

A. The KRI is too sensitive

B. The KRI is not aligned to the actual risk driver or thresholds are too loose

C. The KRI is too new

D. The KRI is missing data

Q145: Explanation

Correct Answer: B

A green KRI after a breach signals misalignment:

- Misalignment hides exposure
- Loose thresholds miss signal
- KRIs must reflect real risk drivers

Critical Trap

A green KRI after a breach signals misalignment.

Q146: Cultural Silence

Question

After a serious incident, no one reported the near-miss that preceded it. What culture failure is MOST likely?

A. Strong culture
B. Fear of blame prevented reporting
C. Excellent training
D. Strong controls

Q146: Explanation

Correct Answer: B

Fear silences early warnings:

- Fear suppresses reporting
- Near-misses are early warnings
- Silence allows escalation into disasters

Critical Trap

Fear silences early warnings.

Q147: Positive Incentives

Question

Which incentive BEST supports risk culture?

A. Rewarding only revenue
B. Rewarding both strong results and risk-aware behavior
C. Rewarding only cost reduction
D. Rewarding silence

Q147: Explanation

Correct Answer: B

Reward behavior you want:

- Balanced rewards shape behavior
- Risk-aware behavior should be recognized
- One-sided rewards create blind spots

Critical Trap

Reward behavior you want to see.

Q148: Board Culture

Question

The board rarely challenges executive reports. What culture risk is MOST likely?

A. Stronger governance
B. Groupthink and reduced independent oversight
C. Better training
D. Faster decisions

Q148: Explanation

Correct Answer: B

Boards must challenge:

- Challenge is essential to oversight
- Silence allows drift
- Boards must ask tough questions

Critical Trap

Boards must challenge, not just accept.

Q149: Culture Measurement

Question

Which is the MOST leading indicator of healthy risk culture?

A. Training completion rate
B. Frequency of near-miss reporting
C. Number of policy documents
D. Vendor count

Q149: Explanation

Correct Answer: B

Near-miss reporting measures trust:

- Near-miss reporting signals trust
- Training is an input, not an outcome
- Document count does not indicate culture

Critical Trap

Near-miss reporting measures trust.

Q150: Executive Exception

Question

An executive routinely bypasses control processes. What culture impact is MOST likely?

A. Stronger controls
B. Others imitate the exception, weakening controls
C. Faster projects
D. Better compliance

Q150: Explanation

Correct Answer: B

Executive exceptions cascade downward:

- Leaders set the norm
- Exceptions normalize bypasses
- Controls decay from the top

Critical Trap

Executive exceptions cascade downward.

Q151: Awareness Resistance

Question

Employees resist security awareness training. What should governance do FIRST?

A. Mandate and punish

B. Understand the resistance and tailor the program to roles and relevance

C. Ignore

D. Reduce training

Q151: Explanation

Correct Answer: B

Tailor training:

- Understanding improves engagement
- Tailoring makes training relevant
- Punishment alone breeds resentment

Critical Trap

Tailor training; do not just mandate.

Q152: Risk Communication

Question

An organization uses fear tactics for risk communication. What is the likely long-term impact?

A. Stronger trust
B. Desensitization and reduced engagement
C. Faster action
D. Better culture

Q152: Explanation

Correct Answer: B

Fear fatigues:

- Fear loses effect
- Engagement drops
- Trust erodes

Critical Trap

Fear fatigues; engagement sustains.

Q153: Culture After Incident

Question

After an incident, leaders focus on blame. What culture risk is HIGHEST?

A. Stronger reporting
B. Reduced future reporting and learning
C. Faster recovery
D. Better controls

Q153: Explanation

Correct Answer: B

Blame blocks learning:

- Blame suppresses disclosure
- Learning requires safety
- Reporting shrinks

Critical Trap

Blame blocks learning.

Q154: Ethics Training

Question

Ethics training exists but is a checkbox exercise. What is the MAIN weakness?

A. Too long
B. It does not change behavior or reinforce culture
C. Too few sessions
D. Wrong location

Q154: Explanation

Correct Answer: B

Checkbox ethics is not ethics:

- Culture requires behavior
- Checkbox training does not reinforce values
- Interactive and scenario-based training is stronger

Critical Trap

Checkbox ethics is not ethics.

Q155: Leadership Modeling

Question

Leaders participate in risk training. What is the MOST likely culture benefit?

A. Lower cost

B. Increased credibility and shared ownership of risk

C. Faster projects

D. More audits

Q155: Explanation

Correct Answer: B

Leaders modeling risk builds culture:

- Leaders modeling behavior builds trust
- Shared ownership strengthens culture
- Participation signals priority

Critical Trap

Leaders modeling risk builds culture.

Q156: Tiering Criteria

Question

Vendors are tiered by contract value. What is the MOST important governance flaw?

A. Too many tiers

B. Contract value is not the same as risk; criticality and data sensitivity should drive tiering

C. Too few tiers

D. Too few vendors

Q156: Explanation

Correct Answer: B

Tier by risk, not spend:

- Risk drives tiering
- Contract value alone misleads
- Tiering should reflect exposure

Critical Trap

Tier by risk, not spend.

Q157: Fourth-Party Visibility

Question

A vendor cannot name its subcontractors. What is the MOST likely governance concern?

- A Hidden risk and weak oversight of the extended supply chain
- B Too many subcontractors
- C Too few invoices
- D Too much training

Q157: Explanation

Correct Answer: A

No visibility, no oversight:

- Visibility enables oversight
- Unknown subcontractors create risk
- Governance requires disclosure

Critical Trap

No visibility, no oversight.

Q158: Vendor Exit Execution

Question

A critical vendor relationship ends abruptly. What governance should have prevented the disruption?

- A. A larger contract
- B. A pre-agreed exit plan with data return and continuity steps
- C. A faster payment
- D. More audits

Q158: Explanation

Correct Answer: B

Exit plans are part of onboarding:

- Exit plans reduce disruption
- Data return is essential
- Continuity protects operations

Critical Trap

Exit plans are part of onboarding.

Q159: Right to Audit

Question

A critical vendor's contract lacks a right-to-audit clause. What is the governance impact?

A. Stronger oversight
B. Limited ability to verify vendor controls
C. Lower risk
D. Faster response

Q159: Explanation

Correct Answer: B

No audit rights, no proof:

- Verification depends on access
- Audits provide evidence
- Without rights, oversight is limited

Critical Trap

No audit rights, no proof.

Q160: Vendor Certification

Question

A vendor holds a certification but recently suffered a breach. What governance lesson applies?

A. Certifications guarantee safety

B. Certifications indicate capability at a point in time; ongoing oversight remains necessary

C. Breaches are impossible with certification

D. Certifications should be abandoned

Q160: Explanation

Correct Answer: B

Certification is not a guarantee:

- Certifications are snapshots
- Continuous oversight is required
- Breaches can still occur

Critical Trap

Certification is not a guarantee.

Q161: Vendor Notifications

Question

The vendor contract allows 30 days to notify of a breach. What governance concern is most relevant?

A. Faster response

B. Delayed notification limits the organization's ability to act quickly

C. Better compliance

D. Lower cost

Q161: Explanation

Correct Answer: B

Slow notification reduces response time:

- Timely notification enables response
- Long windows increase exposure
- Contracts should align to regulatory timelines

Critical Trap

Slow notification reduces response time.

Q162: Vendor Concentration

Question

Three critical vendors depend on the same cloud provider. What risk should be assessed FIRST?

A. Marketing strategy

B. Concentration risk at the underlying provider level

C. HR planning

D. Catering

Q162: Explanation

Correct Answer: B

Look beyond direct vendors:

- Underlying concentration amplifies impact
- Shared dependency increases single points of failure
- Governance must assess chain-wide risk

Critical Trap

Look beyond direct vendors to underlying dependencies.

Q163: Vendor Governance Cadence

Question

Vendor reviews are quarterly for critical vendors and annual for others. Is this governance sound?

A. No, all should be annual
B. Yes, tiered cadence aligned to risk is appropriate
C. No, all should be quarterly
D. No, no reviews needed

Q163: Explanation

Correct Answer: B

Cadence follows criticality:

- Cadence should match criticality
- Critical vendors need closer oversight
- Risk-based review is efficient and effective

Critical Trap

Cadence follows criticality.

Q164: Vendor Incentives

Question

A vendor contract pays more for faster delivery only. What governance risk is created?

- A Faster delivery is always safe
- B Incentives may encourage cutting corners on security
- C Fewer suppliers
- D Higher costs

Q164: Explanation

Correct Answer: B

Incentives shape vendor behavior:

- One-sided incentives skew behavior
- Security must be rewarded too
- Balanced incentives protect the enterprise

Critical Trap

Incentives shape vendor behavior.

Q165: Vendor Data Return

Question

A vendor is required to return all data at contract termination. What governance mechanism BEST verifies this?

A. Trust the vendor

B. Certificate of destruction and audit rights to verify

C. Ignore

D. Delay return

Q165: Explanation

Correct Answer: B

Trust, but verify data return:

- Verification is essential
- Certificates provide evidence
- Audit rights support oversight

Critical Trap

Trust, but verify data return.

Q166: Board Reporting Escalation

Question

The enterprise faces a material risk that has not been reported to the board. What is the MOST likely governance failure?

A. Too many dashboards

B. Missing escalation and reporting paths for material risks

C. Too few vendors

D. Too much training

Q166: Explanation

Correct Answer: B

Material risk belongs on the board's desk:

- Material risk must reach the board
- Escalation paths ensure visibility
- Silence is a governance failure

Critical Trap

Material risk belongs on the board's desk.

Q167: Appetite for Innovation

Question

A board sets a low appetite for operational risk but a high appetite for innovation. What governance guidance follows?

- A Avoid innovation
- B Encourage innovation within defined risk thresholds and governance gates
- C Ignore risk
- D Cancel new ideas

Q167: Explanation

Correct Answer: B

Balance innovation with risk appetite:

- Appetite can differ by risk type
- Gates and thresholds shape safe innovation
- Avoidance and ignoring risk both fail

Critical Trap

Balance innovation with risk appetite.

Q168: Tolerance Breach

Question

A KRI breaches tolerance. What is the FIRST governance expectation?

A. No action
B. Defined escalation and response per governance
C. New KRIs
D. An audit

Q168: Explanation

Correct Answer: B

Tolerance breaches need response:

- Breaches should trigger action
- Defined responses prevent confusion
- Governance requires discipline

Critical Trap

Tolerance breaches need response.

Q169: Reporting Insight

Question

The board receives 300 KRI values. What should governance change FIRST?

A. Add more KRIs

B. Focus on a small set of key indicators with clear ownership and thresholds

C. Reduce the reporting cadence

D. Increase vendor count

Q169: Explanation

Correct Answer: B

Fewer, better indicators:

- Focused indicators drive decisions
- Ownership clarifies action
- Volume obscures signal

Critical Trap

Fewer, better indicators.

Q170: Loss Trending

Question

A risk has been stable for five years but conditions are changing. What should governance require?

A. No action

B. Reassessment and updated indicators

C. Continue as usual

D. Increase ratings

Q170: Explanation

Correct Answer: B

Stable past is not a stable future:

- Stable history may not reflect current risk
- Reassessment catches changes
- Adjustments follow data

Critical Trap

Stable past is not a stable future.

Q171: Assurance Source

Question

A board wants confidence in a critical system's security. Which assurance source is MOST credible?

A. A vendor's marketing statement
B. Independent assurance with evidence
C. The system owner's assurance only
D. An informal email

Q171: Explanation

Correct Answer: B

Evidence and independence build trust:

- Independence and evidence support credibility
- Marketing and informal statements lack rigor
- Self-assessment alone may be biased

Critical Trap

Evidence and independence build trust.

Q172: Appetite Alignment

Question

Business unit investments are expanding beyond appetite. What governance action is MOST appropriate?

A. Ignore the expansion

B. Re-affirm or adjust appetite and align investments to it

C. Increase approvals

D. Cancel all expansion

Q172: Explanation

Correct Answer: B

Investments align with appetite:

- Appetite must guide investments
- Alignment is a leadership decision
- Cancellation needs analysis

Critical Trap

Investments align with appetite, not the reverse.

Q173: Risk Statement Clarity

Question

Which risk statement is MOST likely to prompt action from executives?

- A Some IT risks exist
- B A breach could expose customer records, trigger regulatory fines, and damage brand trust within six months
- C Firewall rules are outdated
- D Log data is large

Q173: Explanation

Correct Answer: B

Consequence and timing drive action:

- Business consequence drives urgency
- Timeframe and impact create meaning
- Technical detail and vagueness lack pull

Critical Trap

Consequence and timing drive action.

Q174: Aggregation Risk

Question

Combined risk exceeds appetite though each unit is within appetite. What does this reveal?

A. Appetite is too strict
B. Aggregation reveals exposure that individual views miss
C. The units are wrong
D. No issue

Q174: Explanation

Correct Answer: B

Portfolio risk beats unit-by-unit views:

- Combined risk can exceed individual limits
- Aggregation reveals systemic exposure
- Appetite should consider the portfolio

Critical Trap

Portfolio risk beats unit-by-unit views.

Q175: Board Challenge

Question

The board asks how a rating was determined. What is the BEST governance response?

A. Provide the methodology, data, and assumptions

B. Decline to answer

C. Reissue the rating higher

D. Postpone

Q175: Explanation

Correct Answer: A

Explain the methodology:

- Transparency builds trust
- Methodology and data support credibility
- Avoidance undermines confidence

Critical Trap

Explain the methodology, not just the number.

Q176: BCP Ownership

Question

The BCP is owned by IT alone. What governance issue is MOST likely?

A. Too much scope
B. Business process priorities and impact may be missing
C. Overfunding
D. Too many tests

Q176: Explanation

Correct Answer: B

BCP must be business-owned:

- Continuity is business-owned
- IT supports recovery
- IT-only plans miss business impact

Critical Trap

BCP must be business-owned.

Q177: BCP Test Results

Question

A BCP test succeeds but the scenario was minor. What governance concern remains?

A. No concern
B. The plan may not hold under realistic or severe scenarios
C. Too many tests
D. Too much budget

Q177: Explanation

Correct Answer: B

Test realistic and severe scenarios:

- Test severity matters
- Realistic scenarios reveal weaknesses
- Minor tests can create false confidence

Critical Trap

Test realistic and severe scenarios.

Q178: Continuity Roles

Question

During a crisis, nobody is sure who is in charge. What is the governance gap?

A. Too many tools
B. Undefined crisis roles and authority
C. Too many policies
D. Too few vendors

Q178: Explanation

Correct Answer: B

Crisis needs clear command:

- Crisis needs clear roles
- Ambiguity slows response
- Authority protects decisions

Critical Trap

Crisis needs clear command.

Q179: Plan Maintenance

Question

The BCP was last updated four years ago. What is governance's BEST action?

A. Approve it as-is

B. Require a review and update to reflect current operations

C. Cancel the plan

D. Archive it

Q179: Explanation

Correct Answer: B

Stale plans fail when needed:

- Plans must reflect current operations
- Reviews keep plans relevant
- Archiving loses readiness

Critical Trap

Stale plans fail when needed.

Q180: Continuity Governance

Question

The board approves the BCP but never reviews test results. What governance gap is MOST likely?

A. Too much oversight
B. Oversight lacks evidence of readiness
C. Too few plans
D. Too many auditors

Q180: Explanation

Correct Answer: B

Oversight requires evidence of readiness:

- Oversight needs test evidence
- Reviews confirm readiness
- Silence implies assumption

Critical Trap

Oversight requires evidence of readiness.

Q181: Investment Oversight

Question

A major IT investment is approved without a business case. What is the governance concern?

- A Speed
- B Value and risk are not demonstrated before spending
- C Fewer approvals
- D Better culture

Q181: Explanation

Correct Answer: B

No business case, no oversight:

- Business cases support value
- Risk and return should be shown
- Approval without analysis is a governance gap

Critical Trap

No business case, no proper oversight.

Q182: Performance Metrics

Question

IT performance is measured only on cost. What governance risk is created?

- A Lower value and higher long-term risk
- B Stronger oversight
- C Faster delivery
- D Better controls

Q182: Explanation

Correct Answer: A

Cost alone is misleading:

- Cost-only metrics ignore value and risk
- Balanced measures protect outcomes
- Single-metric focus creates blind spots

Critical Trap

Cost alone is a misleading metric.

Q183: Change Governance

Question

A production change occurs without change control. What is the MOST likely governance risk?

A. Faster delivery

B. Unassessed risk and untested changes in production

C. Lower cost

D. Better compliance

Q183: Explanation

Correct Answer: B

Change governance prevents surprises:

- Changes need review and testing
- Bypassing control increases risk
- Speed without governance creates exposure

Critical Trap

Change governance prevents surprises.

Q184: Resource Allocation

Question

Resource decisions favor short-term projects over foundational controls. What is the governance risk?

A. Faster short-term results but increased long-term exposure
B. Stronger controls
C. Better culture
D. Lower risk

Q184: Explanation

Correct Answer: A

Short-term wins can hide long-term risk:

- Foundational work protects the enterprise
- Short-term focus can erode resilience
- Balanced investment matters

Critical Trap

Short-term wins can hide long-term risk.

Q185: Value Realization

Question

A project is completed but benefits are not tracked. What governance improvement is BEST?

A. Approve more projects

B. Require post-implementation benefits and risk reviews

C. Cancel the project

D. Increase the budget

Q185: Explanation

Correct Answer: B

Completion is not the same as value:

- Value must be realized
- Reviews confirm outcomes
- Silent completion may hide failure

Critical Trap

Completion is not the same as value.

Q186: Board Technology Committee

Question

A technology committee exists but lacks decision authority. What governance improvement is BEST?

A. Increase meeting frequency

B. Define authority, escalation paths, and reporting lines to the board

C. Add more members

D. Reduce meetings

Q186: Explanation

Correct Answer: B

Committees need authority:

- Authority drives action
- Escalation ensures visibility
- More meetings alone add no power

Critical Trap

Committees need authority and escalation.

Q187: Independent Advice

Question

The board suspects management is downplaying a risk. What governance action is MOST appropriate?

A. Accept management's view
B. Seek independent assurance
C. Ignore the concern
D. Cancel the project

Q187: Explanation

Correct Answer: B

Independence tests management:

- Independent assurance tests management's view
- Boards need objective evidence
- Ignoring concerns increases exposure

Critical Trap

Independence tests what management says.

Q188: Executive Conflict

Question

Two executives disagree on risk acceptance. What should happen NEXT?

A. The more senior wins

B. Escalate to a designated decision authority with documented rationale

C. Ignore

D. Cancel

Q188: Explanation

Correct Answer: B

Conflicts need structured resolution:

- Conflict needs a defined authority
- Documentation preserves accountability
- Silence leaves risk unresolved

Critical Trap

Conflicts need structured resolution.

Q189: Risk Reporting Integrity

Question

A risk report is edited to remove negative findings. What governance issue is MOST visible?

A. Strong oversight

B. Loss of reporting integrity and trust

C. Faster action

D. Lower costs

Q189: Explanation

Correct Answer: B

Report integrity is governance integrity:

- Editing hides exposure
- Boards need honest information
- Trust erodes quickly

Critical Trap

Report integrity is governance integrity.

Q190: Governance of Vendors

Question

A vendor's role is expanded beyond the approved scope without governance approval. What is the governance gap?

A. Scope creep without approval

B. Better contracts

C. Faster delivery

D. Strong culture

Q190: Explanation

Correct Answer: A

Scope changes need approval:

- Expanded scope changes exposure
- Approval ensures oversight
- Silent scope change breaks governance

Critical Trap

Scope changes need approval.

Q191: Crisis Decision Rights

Question

During an incident, decisions are delayed by unclear authority. What should governance define?

A. More meetings

B. Crisis decision rights and escalation with pre-agreed authority

C. Fewer approvals

D. Lower budget

Q191: Explanation

Correct Answer: B

Crisis authority must be predefined:

- Crises need clear authority
- Predefined rights speed response
- More meetings slow it further

Critical Trap

Crisis authority must be predefined.

Q192: Executive Performance

Question

An executive is rewarded despite repeated control failures. What governance signal is most damaging?

A. Incentives matter more than risk
B. Strong oversight
C. Higher morale
D. Better governance

Q192: Explanation

Correct Answer: A

Rewards reveal true priorities:

- Rewards signal priorities
- Rewarding failure undermines risk culture
- Trust erodes

Critical Trap

Rewards reveal true priorities.

Q193: Board Reporting Bias

Question

Reports to the board systematically minimize risk. What governance outcome is MOST likely?

A. Strong oversight
B. Poor decisions and weakened oversight
C. Lower risk
D. Better culture

Q193: Explanation

Correct Answer: B

Minimized risk leads to missed signals:

- Boards need honest input
- Bias leads to missed signals
- Trust is fragile

Critical Trap

Minimized risk leads to missed signals.

Q194: Governance Refresh

Question

The governance framework hasn't been reviewed in years. What should governance do FIRST?

A. Add new members

B. Assess current relevance and align with strategy and regulation

C. Increase meetings

D. Reduce reporting

Q194: Explanation

Correct Answer: B

Frameworks must evolve:

- Frameworks can drift
- Alignment with strategy is essential
- Refresh improves effectiveness

Critical Trap

Frameworks must evolve with the business.

Q195: Business Case Governance

Question

A large program bypasses business-case review. What governance improvement is MOST valuable?

A. More auditors

B. Defined approval gates and criteria for large programs

C. Reduce reporting

D. Add more vendors

Q195: Explanation

Correct Answer: B

Gates and criteria enforce review:

- Gates enforce review
- Criteria ensure consistency
- More auditors do not fix design

Critical Trap

Gates and criteria enforce review.

Q196: Whistleblower Response

Question

A whistleblower reports wrongdoing but receives no response. What is the governance impact?

- A Nothing
- B Loss of trust and future silence
- C Faster reporting
- D Better culture

Q196: Explanation

Correct Answer: B

Silent response means future silence:

- Silence discourages reporting
- Trust decays
- Governance requires response

Critical Trap

Silent response means future silence.

Q197: Risk Appetite Recalibration

Question

The business environment is shifting rapidly. What should governance do with appetite?

A. Ignore the shift

B. Reassess appetite against the new environment with the board

C. Lower appetite without review

D. Freeze all decisions

Q197: Explanation

Correct Answer: B

Appetite must reflect the environment:

- Appetite must fit the environment
- Board re-approval ensures alignment
- Freezing decisions stalls the business

Critical Trap

Appetite must reflect the environment.

Q198: Board Independence

Question

A board member has a financial interest in a vendor under decision. What governance action is required?

A. Vote on the vendor
B. Disclose and recuse
C. Ignore
D. Delegate to the CEO

Q198: Explanation

Correct Answer: B

Disclose and recuse, always:

- Conflicts must be disclosed
- Recusal protects integrity
- Delegation does not remove the conflict

Critical Trap

Disclose and recuse, always.

Q199: Performance Escalation

Question

Repeated missed control commitments from a business unit. What is governance's BEST action?

A. Ignore

B. Require corrective action with accountability and reporting

C. Increase budget

D. Reduce monitoring

Q199: Explanation

Correct Answer: B

Repeated misses demand intervention:

- Missed commitments need action
- Accountability drives change
- Ignoring normalizes failure

Critical Trap

Repeated misses demand intervention.

Q200: Ultimate Governance

Question

When board oversight is weak, what is the MOST likely consequence?

A. Strong risk management
B. Unmanaged risk and stakeholder harm
C. Better controls
D. Lower exposure

Q200: Explanation

Correct Answer: B

Weak oversight exposes stakeholders:

- Oversight is a foundation of governance
- Weak boards invite drift
- Stakeholders bear the consequences

Critical Trap

Weak oversight exposes stakeholders.

Exam Mindset Summary

Remember

- **Governance** directs; **management** executes
- **Accountability** cannot be delegated or outsourced
- **Appetite** is board-owned; **tolerance** is permitted variation
- **Three lines:** operate (1st), oversee (2nd), audit (3rd)
- **Policy** states intent; **standards** specify requirements
- **Culture** follows leadership behavior, not slogans
- **Reporting** needs honesty, clarity, and escalation paths
- **Third parties** need tiering, exit plans, and oversight

Thank You

Good Luck on Your CRISC Exam!